

13-2-2026

Análisis comparativo de metodologías de seguridad informática

CNO V: Seguridad Informática

Nombre:

Morales Hernández Roberto Emiliano

Matrícula:

182377

Servando López Contreras

Grupo T46A

CARTOGRAFIANDO EL PENTESTING

Introducción

Las pruebas de penetración y la evaluación de la seguridad informática son actividades fundamentales para identificar debilidades técnicas, fallas de configuración y deficiencias en los controles de seguridad de los sistemas de información. Para llevar a cabo estos procesos de forma estructurada y profesional, existen diversas metodologías y marcos de referencia que proporcionan guías, fases y criterios estandarizados.

Cada metodología de pentesting tiene un enfoque distinto, ya sea ofensivo, defensivo o evaluativo. Algunas priorizan la simulación de ataques reales, otras se enfocan en la medición objetiva de la seguridad, mientras que algunas sirven como marcos de conocimiento para detección y respuesta. Comprender estas diferencias permite seleccionar la metodología más adecuada según el tipo de sistema, el objetivo de la evaluación y el contexto organizacional.

Tabla Comparativa

METODOLOGÍA	DESCRIPCIÓN	FASES	OBJETIVO	ESCENARIOS	ORIENTACIÓN	AUTORES (URL)	CERTIFICACIONES	VERSIONES
MITRE ATT&CK	Marco de conocimiento que documenta tácticas, técnicas y procedimientos (TTPs) utilizados por atacantes reales, basado en observación de amenazas.	No define fases secuenciales; se organiza en tácticas (Initial Access, Execution, Persistence, etc.) y técnicas.	Identificar y analizar técnicas de ataque reales y mejorar la detección y respuesta.	SOC, threat hunting, red teaming, evaluación de defensas.	Defensa / evaluación	MITRE https://attack.mitre.org	No certificaciones directas (usado como referencia en varias).	Actualización continua (Enterprise, Mobile, ICS).
OWASP WSTG	Guía detallada para pruebas de seguridad en aplicaciones web, enfocado en vulnerabilidades comunes.	Información, configuración, autenticación, autorización, validación de entradas, lógica de negocio, etc.	Detectar vulnerabilidades técnicas en aplicaciones web.	Auditorías web, pentesting web, desarrollo seguro.	Ataque / evaluación	OWASP https://owasp.org/www-project-web-security-testing-guide/	OWASP no certifica WSTG directamente (relacionado con OSCP, CEH).	WSTG v4.x (vigente).

NIST SP 800-115	Guía técnica para pruebas de seguridad y evaluación de sistemas de información.	Planeación, descubrimiento, ataque, reporte.	Evaluar controles de seguridad y postura general.	Gobierno, empresas reguladas, auditorías formales.	Evaluación / defensa	NIST https://csrc.nist.gov/publications/detail/sp/800-115/final	No certificaciones directas.	Publicación vigente (2008, aún referenciada).
OSSTMM	Metodología científica para medir la seguridad operativa de sistemas.	Reconocimiento, análisis de canales, pruebas de control, métricas de seguridad.	Medir objetivamente la seguridad operativa.	Infraestructura crítica, telecomunicaciones, auditorías avanzadas.	Evaluación	ISECOM https://www.isecom.org/OSSTMM.3.pdf	OSSTMM Professional Certification (OPSA, OPST).	OSSTMM v3 (vigente).
PTES	Estándar práctico para la ejecución completa de pruebas de penetración.	Pre-engagement, inteligencia, modelado de amenazas, explotación, post-explotación, reporte.	Estandarizar pruebas de penetración técnicas.	Pentesting profesional, consultoría, ethical hacking	Ataque	Comunidad PTES http://www.pentest-standard.org	Relacionado indirectamente con OSCP, GPEN.	Estándar estable (uso vigente).
ISSAF	Marco integral para pruebas de seguridad con enfoque técnico y procedimental.	Planeación, evaluación, explotación, reporte.	Identificar debilidades técnicas y organizacionales.	Pentesting clásico, auditorías de seguridad.	Ataque / evaluación	OISSG https://www.oissg.org/issaf/	No certificaciones vigentes ampliamente reconocidas.	Marco estable (poca actualización reciente).

Conclusión

El análisis comparativo demuestra que no existe una única metodología universal para todas las evaluaciones de seguridad. Cada marco responde a necesidades específicas y contextos distintos. Metodologías como PTES y OWASP WSTG son ideales para pruebas técnicas ofensivas, mientras que NIST SP 800-115 y OSSTMM resultan más apropiadas para auditorías formales y evaluaciones estructuradas.

Por otro lado, MITRE ATT&CK complementa estas metodologías al proporcionar una visión realista del comportamiento de los atacantes, fortaleciendo la detección y la respuesta a incidentes. En conjunto, estas metodologías permiten al profesional de seguridad adoptar un enfoque integral, combinando ataque, evaluación y defensa para mejorar la postura de seguridad de las organizaciones.

Referencias bibliográficas

- MITRE. (s.f.). MITRE ATT&CK Framework. <https://attack.mitre.org>
- OWASP. (s.f.). Web Security Testing Guide (WSTG). <https://owasp.org/www-project-web-security-testing-guide/>
- NIST. (2008). Special Publication 800-115: Technical Guide to Information Security Testing and Assessment. <https://csrc.nist.gov/publications/detail/sp/800-115/final>
- ISECOM. (s.f.). OSSTMM v3 – Open Source Security Testing Methodology Manual. <https://www.isecom.org>
- PTES Technical Guidelines. (s.f.). Penetration Testing Execution Standard. <http://www.pentest-standard.org>
- OISSG. (s.f.). Information Systems Security Assessment Framework (ISSAF). <https://www.oissg.org/issaf/>